Redes de Información - Trabajo Práctico Especial

Pre-entrega

Acceso Remoto Seguro a la plataforma The Store

Tema 3 (Acceso Remoto Seguro) - Grupo N° 7

Integrantes:

Federico Etchegorry (63175)

Thibault Fricot (69590)

Joaquin Nicolas Yulan Lucioli (60568)

2C 2026

1. Problemática y contexto

The Store es una plataforma de e-commerce de cinco microservicios (**ui** en Java/Spring Boot, **catalog** en Go, **carts** y **orders** en Java, **checkout** en Node.js/NestJS) sobre Kubernetes. Según los manifiestos provistos, cada servicio expone HTTP en el puerto 8080 del pod y se publica como Service ClusterIP en el puerto 80, pero sólo **ui** se expone hacia afuera mediante un Ingress de nginx: el catálogo, carrito, órdenes, checkout, endpoints/actuator y kube-apiserver son alcanzables solo desde dentro de la red del clúster.
Los equipos de desarrollo y operaciones necesitan trabajar contra esos componentes desde redes no confiables. Publicarlos en Internet amplía la superficie de ataque y exponer el apiserver o SSH con IP pública los deja frente a fuerza bruta. La propuesta es interponer una única puerta de entrada cifrada y autenticada: un gateway VPN que identifica a cada usuario por criptografía de clave pública y separa el acceso de red a un servicio interno (dev) del acceso al plano de control (sysadmin). Además, una sucursal necesita consumir los servicios autorizados desde su red local sin instalar un cliente VPN en cada equipo.
Modelo de amenaza: Se asume un atacante con control del segmento no confiable (escaneo, captura de tráfico e inyección de paquetes hacia el gateway) que no posee la clave de la CA ni las claves privadas de los clientes. También se considera un usuario legítimo con perfil dev que intenta alcanzar recursos fuera de su rol (kube-apiserver, SSH) y un equipo de la sucursal que intenta lo mismo a través del túnel site-to-site.

Objetivos: confidencialidad e integridad del tráfico de administración, autenticación mutua, superficie mínima expuesta (único puerto UDP) y capacidad de dar de baja el acceso de un usuario de forma verificable, tanto para nuevas conexiones (CRL) como para la sesión en curso (management interface). Para la sucursal se busca interconexión site-to-site con el mismo control de acceso por origen.

2. Diseño de la solución

Gateway VPN: VM Ubuntu con eth0 en el segmento no confiable (203.0.113.10/24), eth1 en la red interna (10.10.0.1/16) y eth2 en la red de gestión (192.168.100.1/24). Rutea sólo entre el túnel y eth1; la administración del gateway por SSH sólo se acepta por eth2. Concentra openvpn-server sobre UDP/1194; filtrado y NAT con nftables.

Autenticación y PKI: Se utiliza EasyRSA 3 con una CA separada del gateway (192.168.100.20), conectada únicamente a la red de gestión. La clave privada de la CA nunca sale de ella; el gateway sólo almacena los certificados necesarios y la CRL, que recibe por scp sobre la red de gestión. Cada usuario posee un certificado X.509 individual (mTLS); los certificados se emiten en la CA y el perfil .ovpn se entrega por un canal fuera de banda.
Autorización por rol: Tres perfiles (dev, sysadmin y sucursal) con dos capas de control: asignación de IP fija y rutas mediante client-config-dir en OpenVPN, y autorización de acceso mediante reglas nftables en el gateway según la IP de origen.

Perfil	IP de túnel	Acceso autorizado
dev	10.8.0.10–.19	Ingress interno del clúster (10.10.10.5, TCP/80): los cinco microservicios por nombre. Sin kube-apiserver, sin SSH.
sysadmin	10.8.0.20–.29	Suma kube-apiserver TCP/6443 + SSH TCP/22 a la VM k8s-node.
sucursal	10.8.0.30 (red 172.16.20.0/24)	Igual que dev: Ingress TCP/80. Sin apiserver, SSH ni cliente VPN en los equipos.

Publicación interna: Un Ingress con una regla por host publica los cinco servicios dentro del clúster: catalog.the-store.internal y sus pares resuelven al ingress-nginx del nodo, que enruta a cada Service. Es un manifiesto adicional, los microservicios no se tocan.

Resolución y ruteo: El gateway resuelve la zona the-store.internal con dnsmasq, porque CoreDNS no es alcanzable desde fuera del clúster. El perfil dev consulta sólo esa zona a 10.8.0.1 (split-DNS). El perfil sysadmin opera por IP. El cliente conserva su ruta por defecto y sólo la red interna va por el túnel (split-tunnel). El gateway hace SNAT del tráfico del túnel hacia la LAN interna, de modo que el acceso no dependa de rutas estáticas en el nodo.
Interconexión site-to-site: La sucursal (172.16.20.0/24) se conecta mediante gw-sucursal (túnel hacia gw-vpn con certificado propio) sin exponer puertos entrantes. Se configura iroute y route para la red de sucursal y dnsmasq para resolver dominios internos. Los equipos acceden sin cliente VPN y con permisos restringidos mediante nftables al Ingress interno por TCP/80.

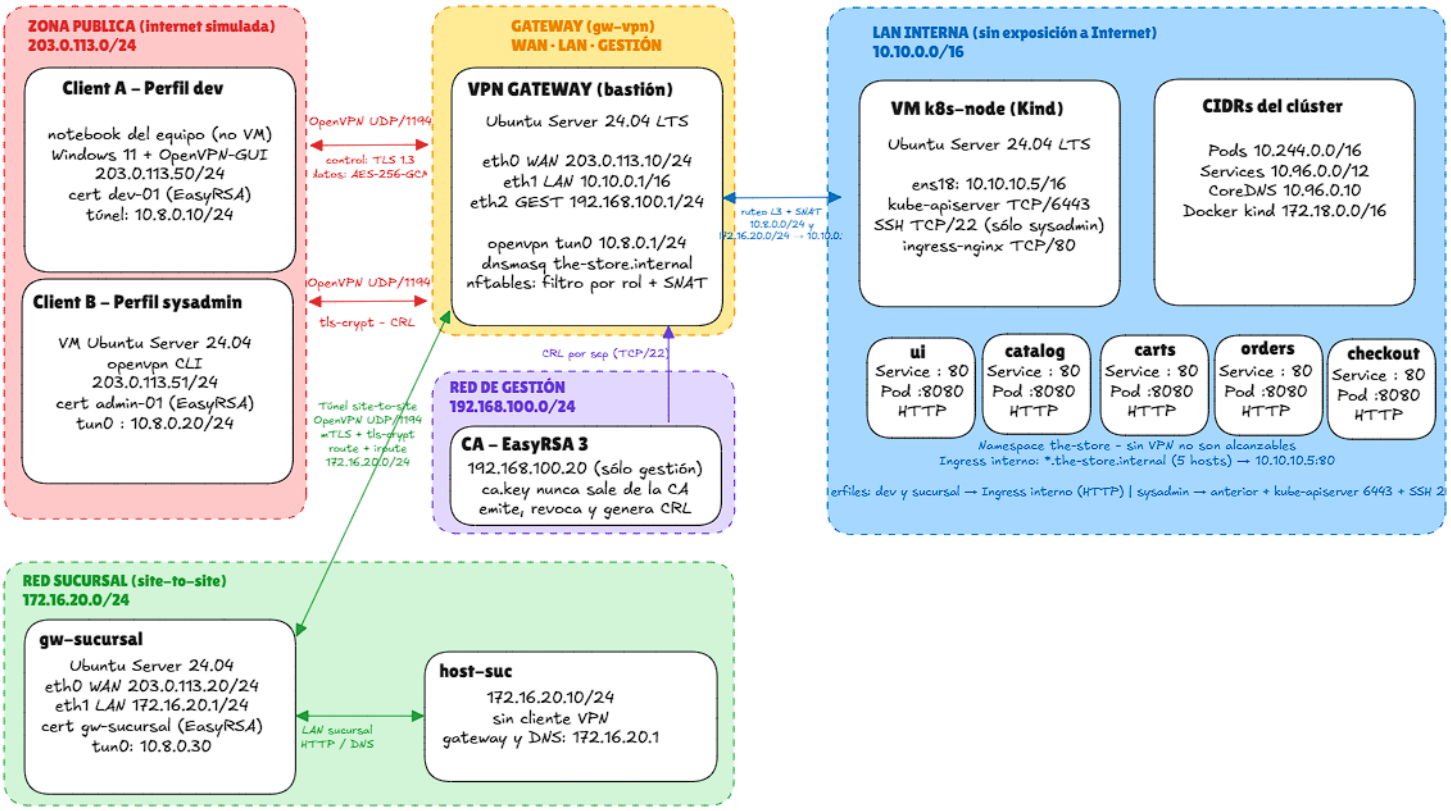
3. Scope del POC y casos de uso

El POC se monta sobre máquinas virtuales con redes aisladas: un segmento dedicado emula Internet y no tiene ruta hacia la red interna salvo a través del gateway. La red de gestión(192.168.100.0/24) es un segmento host-only separado, utilizado para administrar las VMs y transferir la CRL desde la CA al gateway. No participa del camino de datos ni es accesible desde el segmento no confiable. La red de la sucursal sólo se comunica con la red interna a través del túnel entre gw-sucursal y gw-vpn.

VM	Red(es)	Rol
gw-vpn	203.0.113.10 + 10.10.0.1 + 192.168.100.1	Gateway OpenVPN, nftables, publicación de la CRL.
k8s-node	10.10.10.5	Nodo Kind con The Store desplegado.
cli-adm	203.0.113.51	Ubuntu Server con openvpn CLI (perfil sysadmin).
Cliente dev	203.0.113.50	Notebook Windows 11 de un integrante con OpenVPN-GUI (perfil dev).
CA (EasyRSA)	Red de gestión únicamente	Emite/revoca certificados y genera la CRL. Fuera del camino de datos.
gw-sucursal	203.0.113.20 + 172.16.20.1	Segundo gateway OpenVPN (cliente de gw-vpn, certificado propio). Rutea la red de la sucursal por el túnel y reenvía el DNS.
host-suc	172.16.20.10	Equipo de la sucursal sin cliente VPN, con gw-sucursal como puerta de enlace.

#	Caso de uso	Procedimiento	Criterio de aceptación
CU1	Denegación por defecto	Desde cli-adm sin túnel: escaneo del gateway y pruebas contra el Ingress, el apiserver y SSH a k8s-node, primero sin ruta y luego agregando una ruta manual a la LAN vía el gateway.	Un escaneo TCP del gateway no encuentra puertos abiertos. El escaneo UDP no obtiene una respuesta que permita identificar el servicio OpenVPN. Todos los intentos de acceso a la red interna fallan, incluso con la ruta manual: nftables los descarta.
CU2	Alta de usuario y conexión road-warrior	Se emite el certificado del usuario en la CA. Se arma el perfil .ovpn unificado (ca, cert, key, tls-crypt) y se importa en OpenVPN-GUI sobre Windows 11.	El cliente obtiene 10.8.0.10, resuelve ui.the-store.internal y catalog.the-store.internal contra el DNS 10.8.0.1, navega la tienda y consume la API de catalog por nombre; el log del servidor muestra la verificación del certificado.
CU3	Autorización diferenciada por rol	Con el perfil dev se intenta kubectl, SSH al nodo y acceso al Ingress; se repite con el perfil sysadmin. Se muestran el archivo	dev obtiene timeout en 6443 y en SSH, pero accede a los cinco microservicios por el Ingress interno; sysadmin consulta el estado de los pods con

		de client-config-dir y las reglas nftables por IP de túnel.	kubectl y abre sesión SSH al nodo. El control efectivo se demuestra sobre las reglas nftables del gateway y el archivo de client-config-dir.
CU4	Revocación de un usuario	Se revoca el certificado en la CA, se actualiza la CRL en el gateway y se termina específicamente la sesión del usuario revocado mediante la management interface.	La sesión del usuario revocado se termina y los nuevos intentos de conexión son rechazados por la CRL, sin afectar al segundo usuario conectado.
CU5	Confidencialidad, split-tunnel y DNS interno	Con la VPN activa se captura simultáneamente tráfico en el segmento no confiable y en la interfaz interna del gateway durante una consulta HTTP al Ingress. Se muestran además la tabla de ruteo y la resolución DNS del cliente.	En el segmento no confiable, la consulta al servicio interno sólo se observa como tráfico OpenVPN cifrado hacia el gateway. Luego del desencapsulado se observa la comunicación HTTP en claro. El cliente mantiene su ruta por defecto y resuelve the-store.internal vía 10.8.0.1.
CU6	Site-to-site con sucursal	Se emite el certificado de gw-sucursal y se establece el túnel con gw-vpn. Desde host-suc, sin cliente VPN, se prueba el acceso a la tienda, SSH y 6443. Se verifican iroute, nftables y el tráfico capturado.	La sucursal accede a los cinco microservicios por Ingress, pero no a SSH ni 6443. Entre gateways solo se observa tráfico cifrado.



4. Diagrama de arquitectura

Segmento / red	CIDR	Componentes, sistemas operativos y protocolos
Internet simulada	203.0.113.0/24	gw-vpn (.10), gw-sucursal (.20) y clientes remotos dev (.50) y sysadmin (.51).
Túnel OpenVPN (tun0)	10.8.0.0/24	Servidor (.1), clientes dev y sysadmin, y gw-sucursal (.30).
LAN interna	10.10.0.0/16	gw-vpn (10.10.0.1) y nodo Kubernetes con Kind (10.10.10.5), que expone SSH, kube-apiserver e Ingress.
Redes del clúster	10.244.0.0/16 (pods), 10.96.0.0/12 (Services)	Internas del clúster, no se pueden rutear desde afuera. Se accede a los servicios a través del Ingress.
Red de Gestión	192.168.100.0/24	gw-vpn (.1) y CA (.20). Se usa para administración y para copiar la CRL. Fuera del camino de datos.
Red de la sucursal	172.16.20.0/24	gw-sucursal (.1) y host-suc (.10). Los equipos no usan cliente VPN: llegan a la LAN interna sólo a través del túnel site-to-site.

5. Alternativas consideradas

Alternativa	Por qué no se adoptó como solución principal
WireGuard - simple, rápido, en kernel-space y con excelente roaming.	WireGuard utiliza identidades basadas en claves públicas y no incorpora de forma nativa una PKI X.509 con CRL. OpenVPN se eligió porque permite demostrar explícitamente emisión y revocación de certificados.
Tailscale / Headscale	Depende de un plano de control SaaS externo y oculta la capa de red que el TP busca mostrar. Headscale quita la dependencia pero agrega complejidad sin aportar a los objetivos.
IPsec / IKEv2 (strongSwan)	Se descartó por requerir una configuración y troubleshooting más complejos para el alcance del POC.
Bastión SSH + kubectl port-forward	Permite administración remota, pero no brinda acceso de red transparente a los distintos servicios internos. Resuelve un problema diferente al del POC VPN.

6. Matriz de flujos permitidos (mediante nftables)

Todo flujo no listado se descarta: política drop por defecto en input y forward. Las respuestas se permiten por conntrack. El tráfico del túnel y de la sucursal hacia la LAN sale con SNAT a 10.10.0.1.

Origen	Destino	Protocolo / puerto	Dónde se aplica
203.0.113.0/24 (cualquiera)	gw-vpn eth0	UDP 1194	cadena input
Túnel 10.8.0.0/24	gw-vpn tun0 (dnsmasq)	UDP/TCP 53	cadena input
tun0 dev 10.8.0.10–.19 y sucursal 172.16.20.0/24	Ingress interno 10.10.10.5	TCP 80	cadena forward
tun0 sysadmin 10.8.0.20–.29	10.10.10.5	TCP 22, 6443, 80	cadena forward
Red gestión 192.168.100.0/24	gw-vpn eth2	TCP 22	cadena input